Digital Bank Credit Scoring - Threat Model

Owner:
Reviewer:
Contributors:
Release Date: Fri Oct 23 2026

Executive Summary

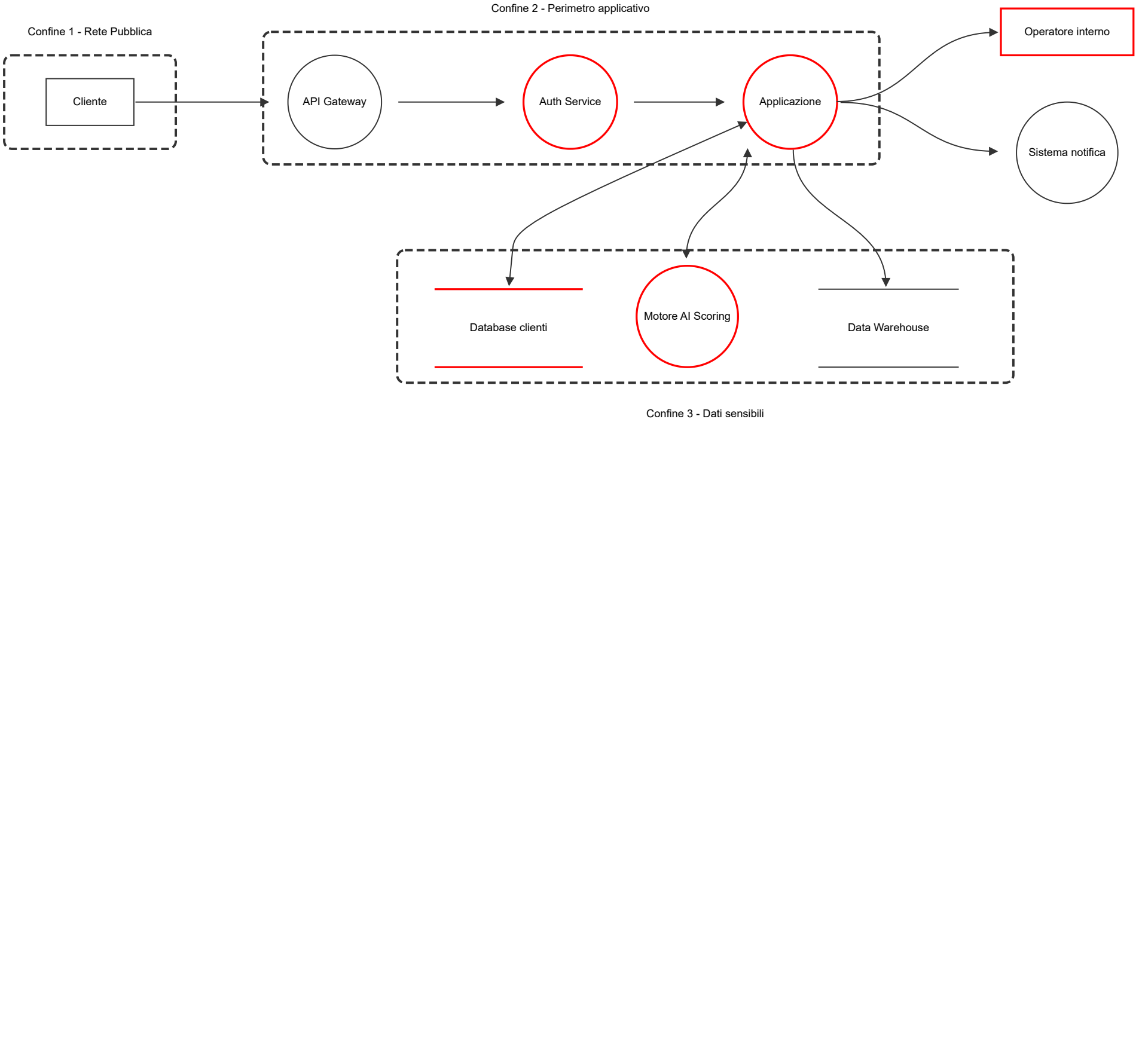
High level system description

Digital bank che offre un servizio di credit scoring basato su un motore AI. Il sistema riceve richieste di prestito dai clienti, calcola un punteggio numerico di affidabilità e restituisce l'esito. Le richieste sospette vengono revisionate da un operatore interno.

Summary

Total Threats	8
Total Mitigated	0
Total Open	8
Open / Critical Severity	0
Open / High Severity	7
Open / Medium Severity	1
Open / Low Severity	0

New STRIDE diagram



New STRIDE diagram

Cliente (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

API Gateway (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Auth Service (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	Furto d'identità del cliente	Spoofing	High	Open		Un attaccante si fa passare per un cliente reale usando credenziali rubate, phishing o MFA fatigue (richieste di conferma ripetute finché l'utente cede), e accede al sistema con un'identità legittima.	MFA resistente al phishing, limite ai tentativi di accesso, blocco dell'account dopo troppi errori, rilevamento di accessi anomali.

Applicazione (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	Abuso dei privilegi dell'applicazione threat	Elevation of privilege	High	Open		Un attaccante che compromette l'applicazione eredita i suoi permessi su database, motore AI e notifiche, e può leggere o alterare dati ben oltre il proprio ruolo.	Permessi minimi per ogni connessione, credenziali separate per ogni servizio, isolamento di rete tra i componenti.
7	Abuso dei privilegi dell'applicazione	Elevation of privilege	High	Open		Un attaccante che compromette l'applicazione eredita i suoi permessi su database, motore AI e notifiche, e può leggere o alterare dati ben oltre il proprio ruolo.	Permessi minimi per ogni connessione, credenziali separate per ogni servizio, isolamento di rete tra i componenti.

(Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

(Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

(Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

(Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

(Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

(Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

(Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Operatore interno (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	Impersonificazione di un operatore interno	Spoofing	High	Open		Un attaccante usa le credenziali rubate di un operatore per accedere alle richieste sospette e modificare i punteggi come se fosse lui.	MFA resistente al phishing per gli operatori, accessi solo da rete aziendale, monitoraggio di accessi anomali.

Sistema notifica (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Data Warehouse (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Motore AI Scoring (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Data poisoning: dati manipolati falsano il punteggio	Tampering	High	Open		Un attaccante o un errore di processo altera i dati cliente usati come input. Il modello restituisce un punteggio falsato, con rischio di concedere o negare credito in modo errato.	Validazione degli input, controlli di integrità sui dataset
2	Model extraction tramite query ripetute	Information disclosure	Medium	Open		Un attaccante interroga il modello molte volte per ricostruirne il comportamento o aggirarne i criteri.	Rate limiting sulle inferenze, monitoraggio di pattern di query anomali, autenticazione obbligatoria.

Database clienti (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	Accesso non autorizzato ai dati dei clienti	Information disclosure	High	Open		Un attaccante o un utente interno accede al database e copia dati anagrafici e finanziari dei clienti, con danno di riservatezza e rischio normativo (GDPR).	Cifratura dei dati a riposo, accessi con privilegi minimi, audit log di ogni lettura, monitoraggio di accessi anomali.
4	Alterazione dei dati di un cliente per falsare il punteggio	Tampering	High	Open		Un attaccante modifica reddito o storico di un cliente, così il motore AI assegna un punteggio più alto e viene concesso un credito non dovuto.	Permessi di scrittura minimi, log immutabili delle modifiche, controllo incrociato dei dati con fonti esterne, doppia approvazione sulle modifiche sensibili.

(Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations